MODULE 5 · LECTURE 24

CS 6530 Applied Cryptography

IPsec Architecture, Policy, ESP and Security Associations

Module 5 – IPsec, IKE and Secure Gateways

Why Protect Traffic at the IP Layer?

Application
TCP / UDP
IP ← *IPsec protects here*
Network



Confidentiality

Prevent disclosure

Integrity / Authentication

Detect unauthorized modification and authenticate protected packets

Anti-Replay

Detect unacceptable replay of previously received protected packets

INSIGHT

Network-layer protection can secure traffic independently of the applications generating it.

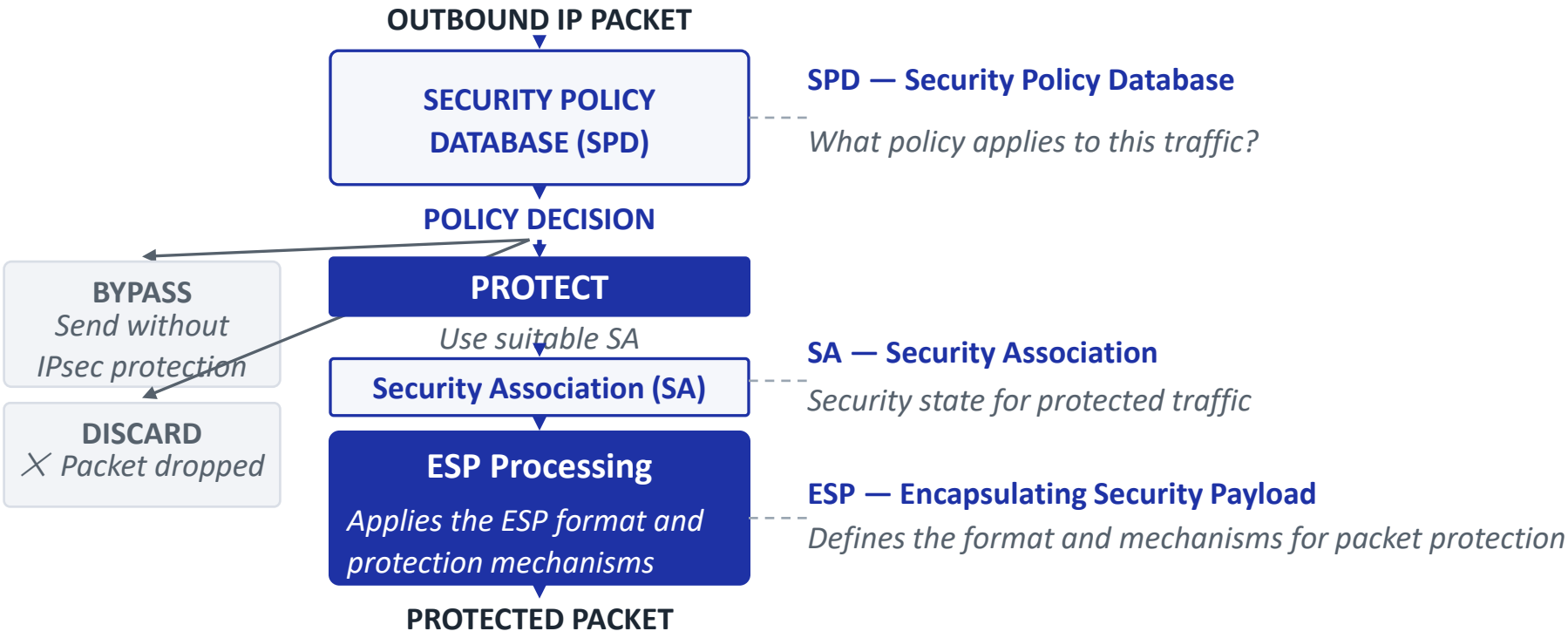
? THINK LIKE AN ENGINEER

Why might we protect traffic at the IP layer rather than require every application to protect itself?

IPsec protects IP traffic, transparent to applications.

IPSEC · MENTAL MODEL

What Happens When an IP Packet Meets IPsec?



INSIGHT

Cryptography comes after policy: IPsec first decides what should happen, then applies protection.

? THINK LIKE AN ENGINEER

Before choosing an algorithm or key, how does the system know whether this packet should be protected at all?

Policy decides what to protect; SA provides the parameters for protection.

IPSEC · PROTECTION SCOPE

What Exactly Does IPsec Protect in ESP – Transport and Tunnel Modes?

ORIGINAL IP PACKET

IP Header	TCP/UDP	Data

TRANSPORT MODE

Original IP Header	ESP Header	TCP/UDP	Data	ESP Trailer	Auth/ Tag

Original IP header stays outside ESP, used for routing.

TUNNEL MODE

New Outer IP Header	ESP Header	IP Hdr	TCP/UDP	Data	ESP Trailer	Auth/ Tag

The entire original packet becomes ESP's protected payload.

WORKED EXAMPLE · SITE-TO-SITE IPSEC TUNNEL



`Inner packet: 10.1.0.10 → 10.2.0.10` `Outer packet: 192.0.2.1 → 192.0.2.2`

INSIGHT

In tunnel mode, outer addresses route the packet; original addresses stay hidden inside ESP.

? THINK LIKE AN ENGINEER

Which addresses must remain visible to routers carrying an IPsec tunnel across an intervening network?

Transport protects the payload; tunnel wraps the packet.

What Does ESP Add to an IP Packet?



SPI – Security Parameters Index
Identifies the Security Association (SA) for the packet

Payload Data
IP packet data carried by ESP

Next Header
Identifies the Payload Data type

Sequence Number
Supports anti-replay processing

Padding / Pad Length
Supports alignment; records padding length

Auth Data / Integrity Check Value (ICV) / Tag
Integrity result when required

"Padding may be needed for cryptographic or ESP alignment. Pad Length tells the receiver how much padding to remove."

TRANSPORT MODE

```
Payload = TCP hdr + data
Next Header = TCP
```

TUNNEL MODE

```
Payload = Orig. IPv4 pkt
Next Header = IPv4
```

INSIGHT

ESP combines protected content with the protocol information needed to process it securely. Protocol information is carried in its header and trailer.

? THINK LIKE AN ENGINEER

If ESP carried only encrypted payload data, what information would the receiver be missing?

ESP pairs security metadata with protected payload data.

How Precisely Can IPsec Identify Traffic?

IP TRAFFIC

▼

TRAFFIC SELECTORS

Source IP / range	Destination IP / range
Next-layer protocol	Source port*
Destination port*	

** where applicable*

▼

SECURITY POLICY DATABASE (SPD)
Which policy matches?

▼

MATCHING SECURITY POLICY

▼

BYPASS / DISCARD / PROTECT

Security Policy Database (SPD)

Policy + traffic classification + required IPsec processing

Illustrative SPD Entries (source 10.1.0.0/24)

Destination	Protocol	Port	Action
10.2.0.0/24	ANY	ANY	PROTECT
10.2.0.20	TCP	443	PROTECT
10.2.0.30	TCP	22	DISCARD

Not an exhaustive field list.

SYSTEM VIEW · LINUX SPD ⇔ `ip xfrm policy`

Observe the selectors, direction and required IPsec processing..

```
cs6530user@CS6530-Lab-B:~/CS6530_Offline/Assign3$ sudo ip xfrm policy
src 10.2.0.0/24 dst 10.1.0.0/24
        dir out priority 375423
        tmpl src 192.0.2.2 dst 192.0.2.1
                proto esp spi 0xc11315c4 reqid 1 mode tunnel
src 10.1.0.0/24 dst 10.2.0.0/24
        dir fwd priority 375423
        tmpl src 192.0.2.1 dst 192.0.2.2
                proto esp reqid 1 mode tunnel
src 10.1.0.0/24 dst 10.2.0.0/24
        dir in priority 375423
        tmpl src 192.0.2.1 dst 192.0.2.2
                proto esp reqid 1 mode tunnel
```

INSIGHT

A security policy applies to a selected class of traffic—not merely to a pair of hosts or networks.

Policy applies in both directions: it governs outbound treatment and inbound acceptance.

? THINK LIKE AN ENGINEER

How can two packets between the same networks be subject to different IPsec policies?

Selectors let the SPD match traffic to the right policy.

Once Policy Says PROTECT, What Happens Next?



Security Association Database (SAD)

Holds established Security Associations used for IPsec packet processing

SA_1 (A → B)

SA_2 (A ← B)



ONE SA = ONE DIRECTION

Each direction is an independent stream of protected packets.
Its sequence-number and anti-replay state evolve independently.

SYSTEM VIEW ·

LINUX . SA state

#ip xfrm state

Observe the security state used for IPsec packet processing.

```
cs6530user@CS6530-Lab-B:~/CS6530_Offline/Assign3$ sudo ip xfrm state
[sudo] password for cs6530user:
Sorry, try again.
[sudo] password for cs6530user:
src 192.0.2.2 dst 192.0.2.1
        proto esp spi 0xc11315c4 reqid 1 mode tunnel
        replay-window 0 flag af-unspec
        auth-trunc hmac(sha256) 0x6c313b4c383cd63aa689f66f46e81b6415ad3ceb06a2ea572b7dfdc345ca1daa 128
        enc cbc(aes) 0xe127739f365a06c2c415dd40da404a1bdf221829c2df36108a06bfda3be853bb
        anti-replay context: seq 0x0, oseq 0x0, bitmap 0x00000000
src 192.0.2.1 dst 192.0.2.2
        proto esp spi 0xc0bfa0e3 reqid 1 mode tunnel
        replay-window 32 flag af-unspec
        auth-trunc hmac(sha256) 0x45f05a99a6e198077c93e26895afe7977db1e643be7124d09b30d4df36fcb92a 128
        enc cbc(aes) 0x1f933d98ebd76e3b229c5a7370590196ebc7776117655dc808503038d58bad9c
        anti-replay context: seq 0x0, oseq 0x0, bitmap 0x00000000
cs6530user@CS6530-Lab-B:~/CS6530_Offline/Assign3$
```

INSIGHT

A bidirectional protected conversation requires two SAs—one for each direction.

? THINK LIKE AN ENGINEER

What is the benefit of using separate SAs for the two directions between two endpoints?

Separate SAs let each traffic direction maintain its security state independently.

What Security State Does an SA Hold?

SECURITY ASSOCIATION (SA)

SA PARAMETERS - *Fixed for this SA*

SPI – 32 bit SA identifier	Mode
Algorithms	Keys
Lifetime	Tunnel Endpoints

PER-SA DYNAMIC STATE - *Evolves per packet*

Sequence Number	Anti-Replay State

Finite SA lifetime → rekey / replacement SA → fresh keying material (fresh keys)

How are SAs established?

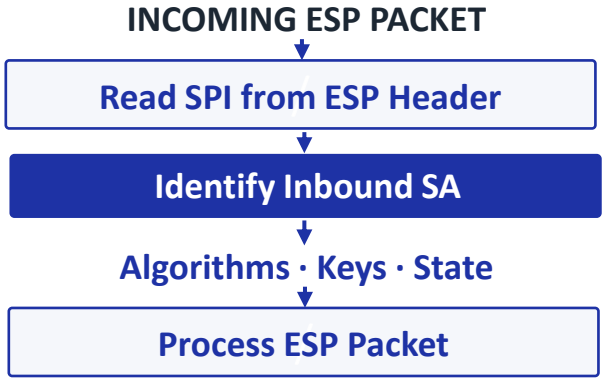
Manual Configuration | IKE

INSIGHT

An SA binds the parameters and protocol state needed to consistently protect and process a traffic direction.

THINK LIKE AN ENGINEER

If an IPsec gateway maintains many SAs, how can an arriving ESP packet quickly identify the SA needed to process it?



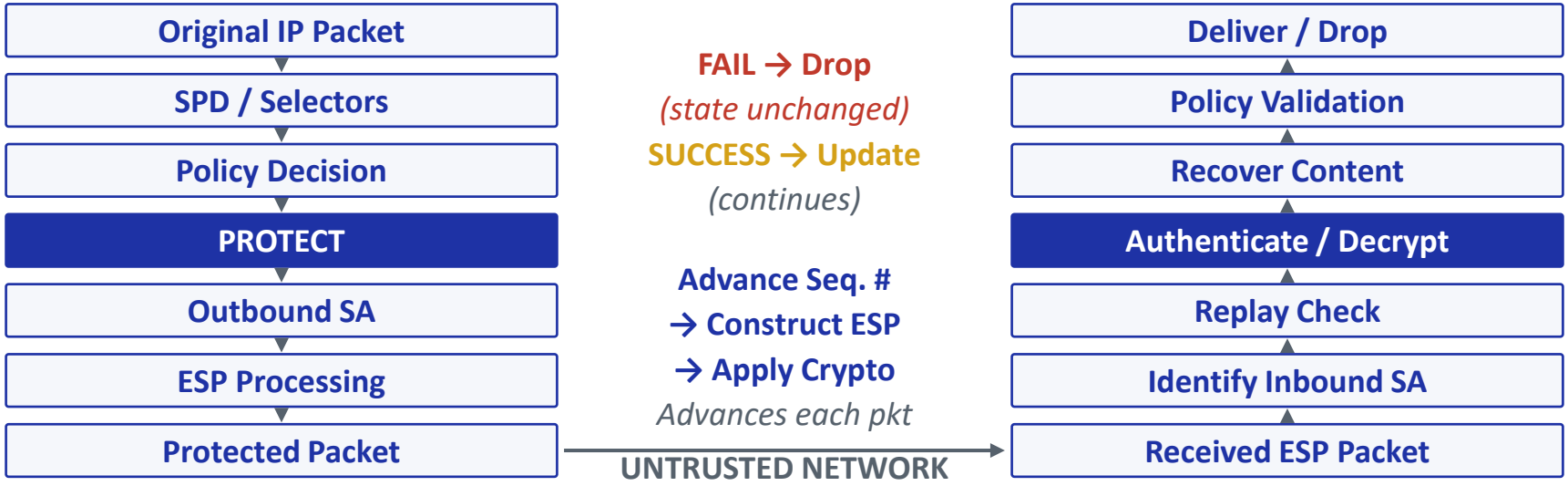
OBSERVE IN A REAL ESP PACKET

```
Frame 6: 150 bytes on wire (1200 bits), 150 bytes captured (1200 bits)
Ethernet II, Src: Dell_4a:d7:0a (00:11:43:4a:d7:0a), Dst: 00:00:00_00:00:12 (00:00
Internet Protocol Version 4, Src: 190.0.0.1, Dst: 190.0.0.2
   0100 .... = Version: 4
   .... 0101 = Header Length: 20 bytes (5)
   Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
   Total Length: 136
   Identification: 0x0004 (4)
   010. .... = Flags: 0x2, Don't fragment
   ...0 0000 0000 0000 = Fragment Offset: 0
   Time to Live: 64
   Protocol: Encap Security Payload (50)
   Header Checksum: 0xbe3c [validation disabled]
   [Header checksum status: Unverified]
   Source Address: 190.0.0.1
   Destination Address: 190.0.0.2
   [Stream index: 0]
Encapsulating Security Payload
   ESP SPI: 0x0000006e (110)
   ESP Sequence: 23
   ESP IV: 48e0dee72649d11764e53ddb7f19dd94 (16 bytes)
   ESP Encrypted Data: 8ca8ff34575b92a4a568788483c169fbf2d9ce742ea0148fa9be5e285db
   ESP ICV: dff67d8a7d0ba16be25e471d (12 bytes) <HMAC-SHA-1-96 [RFC2404]> [correct
      [Good: True]
      [Bad: False]
   ESP Decrypted Data: 0800390fd463000561a8f9439b98090008090a0b0c0d0e0f10111213141
      ESP Contained Data: 0800390fd463000561a8f9439b98090008090a0b0c0d0e0f101112131
      Pad: 0102030405060708090a0b0c0d0e
      ESP Pad Length: 14
      Next header: ICMP (0x01)
Internet Control Message Protocol
```

Security association (SA) pairs fixed parameters with evolving per-SA state.

IPSEC · PACKET PROCESSING

How Does ESP Process Traffic in Both Directions?



SAME ARCHITECTURE, DIFFERENT PROTECTION SCOPE

TRANSPORT — header stays outer

TUNNEL — new outer header added

INSIGHT

Outbound and inbound use the same policy, SA and ESP functions—but separate per-direction state.

? THINK LIKE AN ENGINEER

Why must the receiver authenticate a packet before allowing it to change the inbound SA's replay state?

Sender applies policy; receiver verifies before delivery.

How Does ESP Detect Replayed Packets?

SENDER
Outbound SA + Seq. Ctr

ESP Packet →

RECEIVER
Inbound SA + Replay Win

THE ANTI-REPLAY WINDOW IS RECEIVER-SIDE, PER INBOUND SA

Illustrative Window (W = 8) — highest authenticated: 108

RFC 4303: min. 32; default 64 preferred

101	102	103	104	105	106	107	108
✓	✓	✓	✓	✓	·	✓	✓
					unseen		*highest*

Packet	Receiver Observation	Result
106	Inside window; not yet seen	Accept after authentication
107	Inside window; already seen	Reject — replay
109	Ahead of the current window	Accept after authentication; window → 102–109
100	Left of the window (too old)	Reject — too old

The right edge of the Window is anchored at the highest successfully authenticated sequence number received so far.

INSIGHT

Anti-replay must reject duplicate authenticated packets without rejecting legitimate packets that arrive out of order.

? THINK LIKE AN ENGINEER

Why can the receiver not simply reject every packet whose sequence number is lower than the highest number already received?

Anti-replay blocks duplicates, not legitimate reordering.

Where Do the Cryptographic Algorithms Fit?

HOW CAN ESP PROVIDE CONFIDENTIALITY + INTEGRITY?

OPTION 1 — SEPARATE CRYPTOGRAPHIC FUNCTIONS

Encryption +
Integrity / Authentication

`Example: AES-CBC + HMAC-SHA-2`

Traditional construction: separate functions

OPTION 2 — AEAD

Authenticated Encryption
with Associated Data

`Example: AES-GCM`

Integrated AEAD construction

Separate encryption + integrity → AEAD integrates these functions

The SA specifies the cryptographic transforms and keys used for this ESP traffic.

AES-GCM IN ESP

Visible metadata (the relevant visible ESP fields)
AUTHENTICATED AS AAD

→

Protected content
ENCRYPTED + AUTHENTICATED

INSIGHT

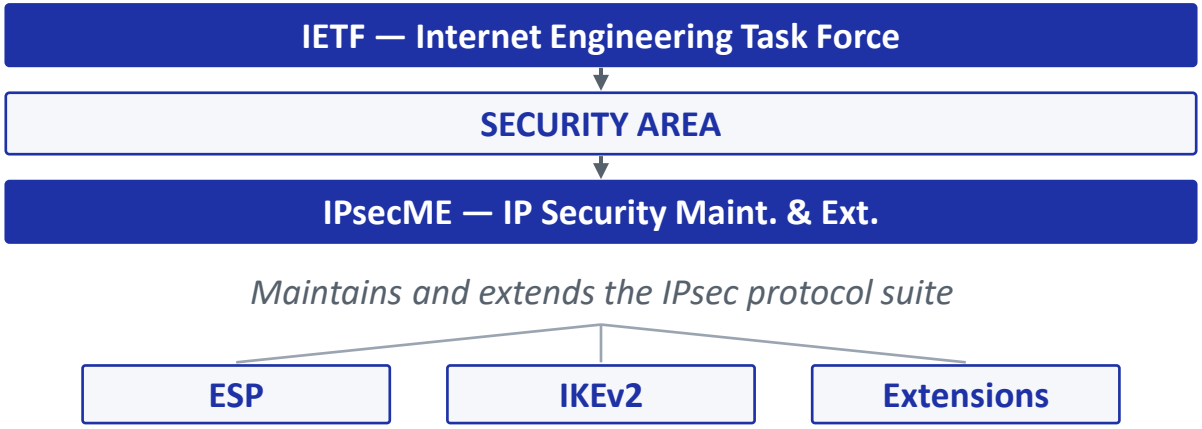
ESP obtains confidentiality and integrity via separate cryptographic functions or one integrated AEAD construction.

? THINK LIKE AN ENGINEER

Why is AEAD attractive when both confidentiality and integrity are required for protected traffic?

The SA determines the cryptographic construction, algorithms and keys ESP uses.

Who Maintains and Evolves IPsec?



WHY DOES A MATURE SECURITY PROTOCOL CONTINUE TO EVOLVE?

Protocol Maint.	Crypto Updates	IKEv2 Updates	Post-Quantum

Standards evolve as deployment experience, algorithms and security requirements change.

EXPLORE THE LIVE STANDARD

`IETF Datatracker → Security Area → IPsecME (IP Security Maintenance and Extensions)`

INSIGHT

IPsec is mature, but standards evolve as cryptography, deployment and threats change.

? THINK LIKE AN ENGINEER

Why does a mature, widely used security protocol still need active standards maintenance?

The IETF IPsecME group maintains and extends IPsec standards as needs evolve.

References and Further Reading

TEXTBOOK

William Stallings — Cryptography and Network Security (Pearson)

Relevant topic: IP Security / IPsec

IETF STANDARDS

RFC 4301 — Security Architecture for the Internet Protocol

S. Kent, K. Seo

IPsec architecture, policy, SAs, SPD/SAD and processing model.

RFC 4303 — IP Encapsulating Security Payload (ESP)

S. Kent

ESP format, transport/tunnel modes, sequence numbers, anti-replay.

RFC 8221 — Crypto Algorithm Requirements for ESP/AH

P. Wouters et al.

Cryptographic algorithm implementation and usage guidance.

RFC 7296 — Internet Key Exchange Protocol Version 2 (IKEv2)

C. Kaufman et al.

Key management and SA establishment; bridges to next lecture.

ACTIVE STANDARDS WORK

IETF Security Area · IPsecME Working Group

Standards status and ongoing work: consult the IETF Datatracker.